CA1 - Open Source Firewalls Assignment

By Roman Oleinikov and Pavlo Panchenko

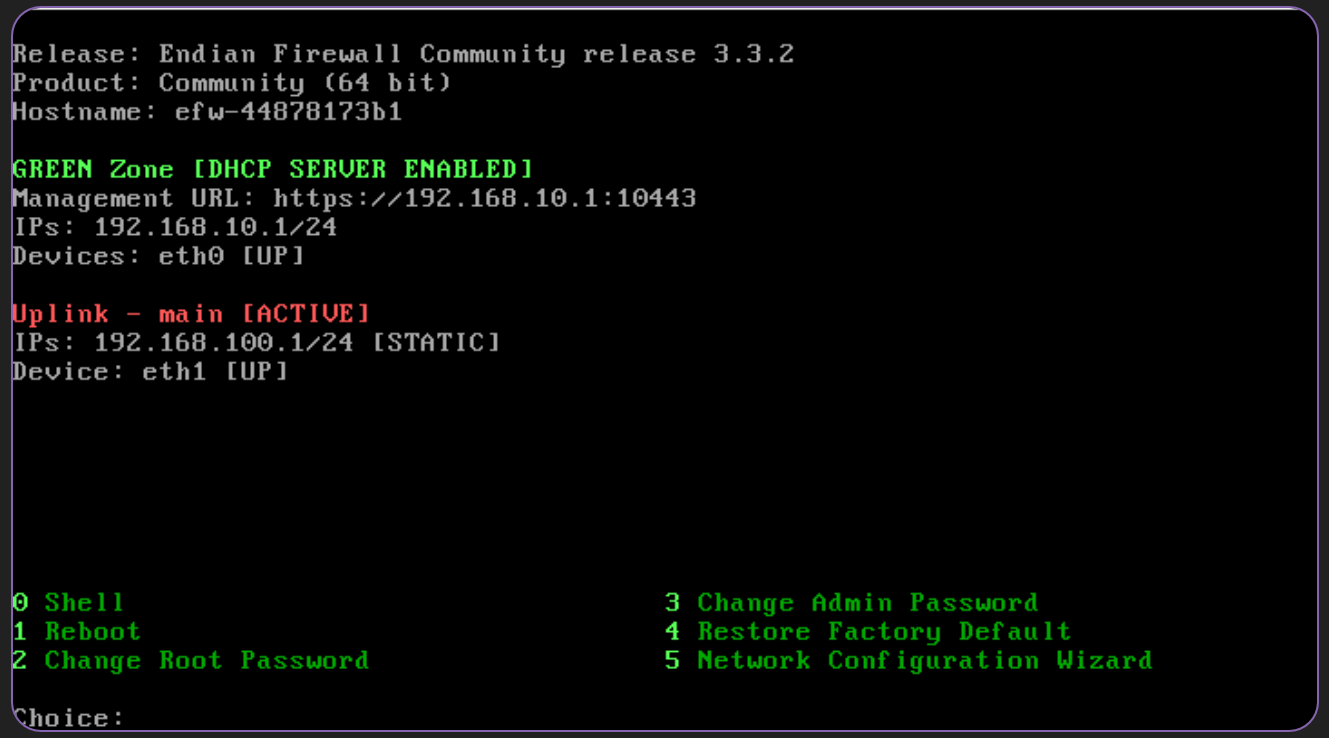
Endian community release firewall



- Endian is Linux based UTM stateful firewall based on the iptables which the firewall interacts with to analyze packets.
- Endian uses Zone-Based-Policy, offering Green, Red, Orange and Blue zones. For the following project LAN-to-Internet design was used with Red zone as external network and Green zone as internal network.

Firewall configuration

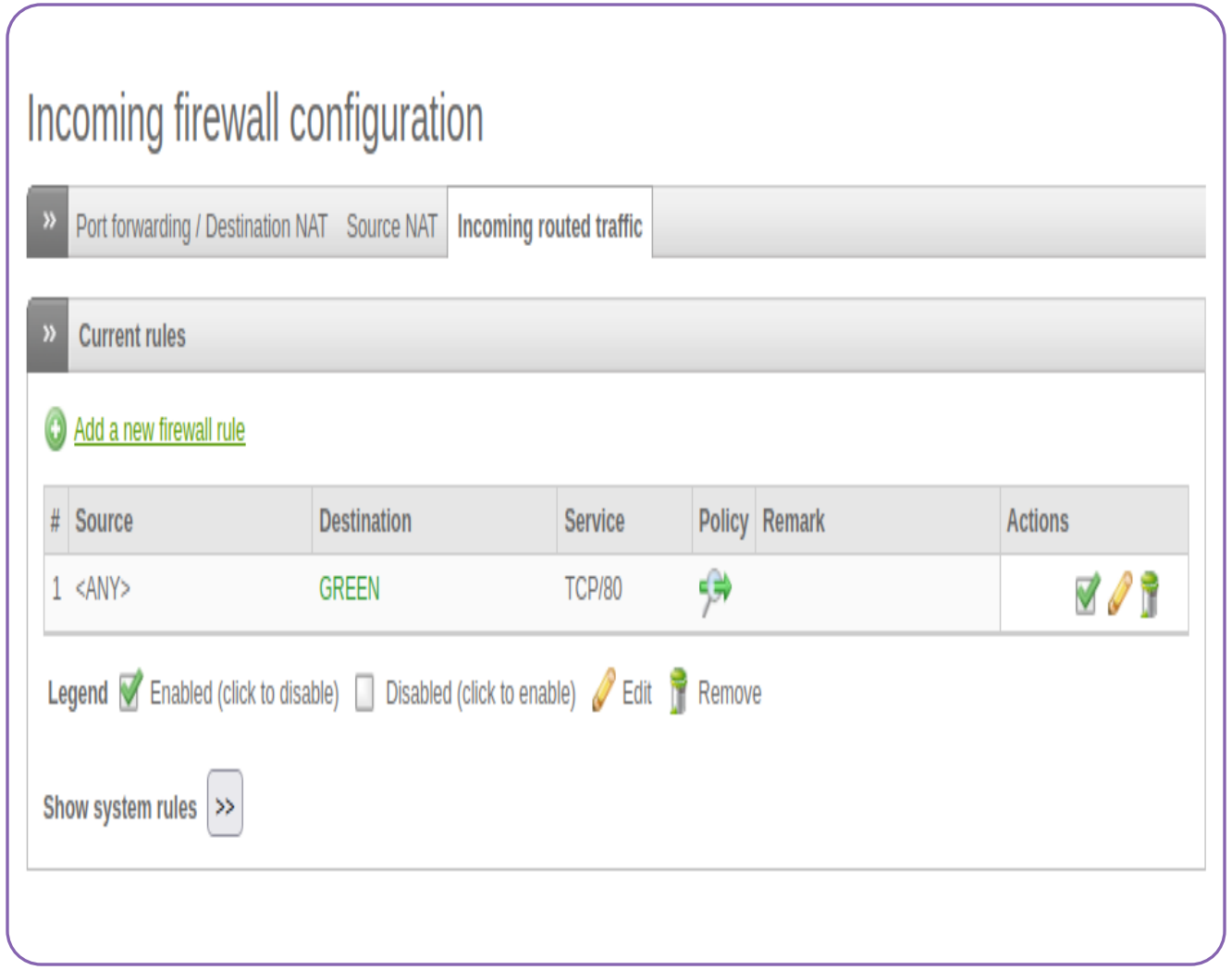
- Eth0 – which is used for the "Green zone" of the firewall. .
- Eth1 – is configured as the uplink between the external network (Red zone) and the Green zone. On the external side of the network a Kali Linux virtual machine is created to run the test on the firewall rules.



Firewall configuration

System access to the firewall itself was disabled for all zones except for the green.

The only connection allowed from the Red zone to Green zone was http on port 80.



SSH and PING

We attempted to ssh to the Metasploitable server, but our attempt was blocked by firewall.
Same thing happened with ping command

```
┌──(roman㉿vbox)-[~]
└─$ ssh -oHostKeyAlgorithms=+ssh-rsa \
    -oPubkeyAcceptedKeyTypes=+ssh-rsa \
    msfadmin@192.168.10.2
^C

┌──(roman㉿vbox)-[~]
└─$ ping  192.168.10.2
PING 192.168.10.2 (192.168.10.2) 56(84) bytes of data.
^C
--- 192.168.10.2 ping statistics ---
15 packets transmitted, 0 received, 100% packet loss, time 14324ms
```

Firewall	2025-11-03 23:39:25	FORWARD:DROP TCP (eth1) 192.168.100.10:58314 -> 192.168.10.2:22 (br0)
Firewall	2025-11-03 23:39:26	FORWARD:DROP TCP (eth1) 192.168.100.10:58314 -> 192.168.10.2:22 (br0)
Firewall	2025-11-03 23:39:29	FORWARD:DROP TCP (eth1) 192.168.100.10:58314 -> 192.168.10.2:22 (br0)
Firewall	2025-11-03 23:39:48	FORWARD:DROP eth1 (eth1) 192.168.100.10:br0 -> 192.168.10.2:08:00:27:4c:3a:c0:08:00:27:72:ac:be:08:00 (br0)
Firewall	2025-11-03 23:39:49	FORWARD:DROP eth1 (eth1) 192.168.100.10:br0 -> 192.168.10.2:08:00:27:4c:3a:c0:08:00:27:72:ac:be:08:00 (br0)
Firewall	2025-11-03 23:39:50	FORWARD:DROP eth1 (eth1) 192.168.100.10:br0 -> 192.168.10.2:08:00:27:4c:3a:c0:08:00:27:72:ac:be:08:00 (br0)

NMAP

Firstly, stealth NMAP scan was used to check if Intrusion prevention system would recognize it and warn about it. But no log messages were displayed by IPS. Only usual drop of packets from the firewall on restricted ports.

```
┌──(roman㉿vbox)-[~]
└─$ nmap -sS -p1-1000 -Pn 192.168.10.2
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-03 22:53 GMT
Nmap scan report for 192.168.10.2
Host is up (0.0099s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT   STATE SERVICE
80/tcp open  http

Nmap done: 1 IP address (1 host up) scanned in 19.78 seconds
```

Firewall	2025-11-03 23:53:22	FORWARD:DROP TCP (eth1) 192.168.100.10:42565 -> 192.168.10.2:139 (br0)
Firewall	2025-11-03 23:53:22	FORWARD:DROP TCP (eth1) 192.168.100.10:42565 -> 192.168.10.2:587 (br0)
Firewall	2025-11-03 23:53:22	FORWARD:DROP TCP (eth1) 192.168.100.10:42565 -> 192.168.10.2:25 (br0)
Firewall	2025-11-03 23:53:25	INCOMINGFW:ALLOW:1 TCP (eth1) 192.168.100.10:42565 -> 192.168.10.2:80 (br0)
Firewall	2025-11-03 23:53:27	INCOMINGFW:ALLOW:1 TCP (eth1) 192.168.100.10:42570 -> 192.168.10.2:80 (br0)
Firewall	2025-11-03 23:53:28	INCOMINGFW:ALLOW:1 TCP (eth1) 192.168.100.10:42572 -> 192.168.10.2:80 (br0)

NMAP

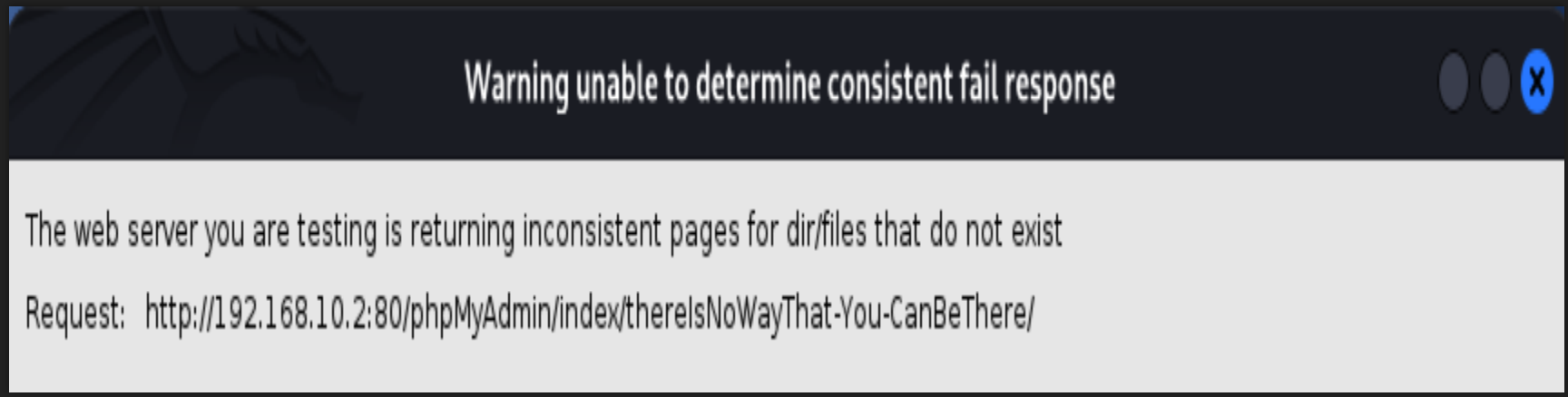
Secondly, we used NMAP vuln script to see what sort of vulnerabilities we will find with and without IPS turned on. With IPS on, output of NMAP was able to find more http-csrf vulnerabilities but did not find the Slowloris vulnerability of the web server.

```
30/tcp open  http    Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-trace: TRACE is enabled
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_http-vuln-cve2017-1001000: ERROR: Script execution failed (use -d to debug)
| http-slowloris-check:
|   VULNERABLE:
|   Slowloris DOS attack
|     State: LIKELY VULNERABLE
|     IDs:  CVE:CVE-2007-6750
|       Slowloris tries to keep many connections to the target web server open a
nd hold
|       them open as long as possible.  It accomplishes this by opening connecti
ons to
|       the target web server and sending a partial request. By doing so, it sta
rves
|       the http server's resources causing Denial Of Service.
|
|     Disclosure date: 2009-09-17
|     References:
|       http://ha.ckers.org/slowloris/
|_      https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
```

Intrusio..	2025-11-04 00:05:45	snort[3887]: [1:2009358:5] ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine) [Classification: Web Application Attack] [Priority: 1] {TCP} 192.168.100.10:47646 -> 192.168.10.2:80
Intrusio..	2025-11-04 00:05:45	snort[3887]: [1:2009358:5] ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine) [Classification: Web Application Attack] [Priority: 1] {TCP} 192.168.100.10:47652 -> 192.168.10.2:80
Intrusio..	2025-11-04 00:05:45	snort[3887]: [1:2009358:5] ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine) [Classification: Web Application Attack] [Priority: 1] {TCP} 192.168.100.10:47666 -> 192.168.10.2:80
Intrusio..	2025-11-04 00:05:45	snort[3887]: [1:2009358:5] ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine) [Classification: Web Application Attack] [Priority: 1] {TCP} 192.168.100.10:47678 -> 192.168.10.2:80

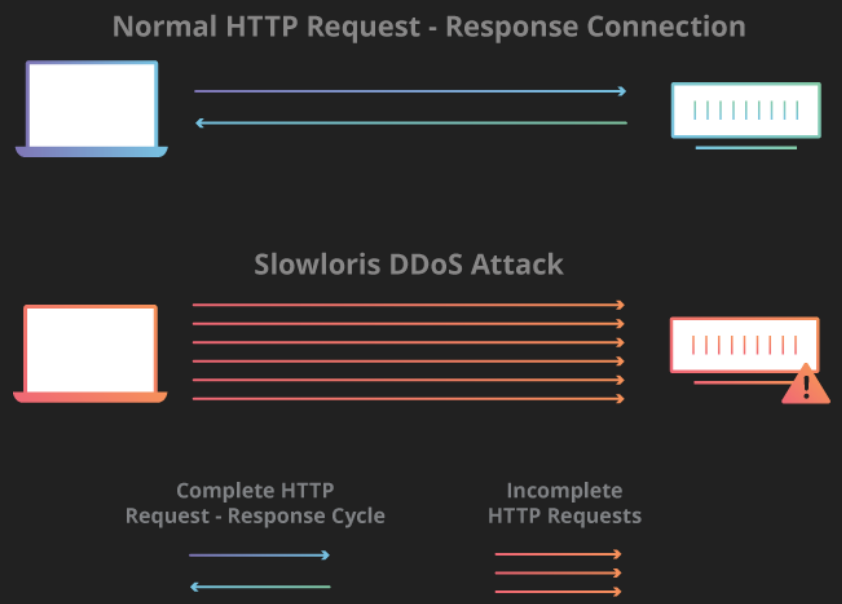
Dirbuster

Dirbuster was used to check if IPS is impacting the result of NMAP scan, With IPS on, we received warning that inconsistent pages are returned by web server.



Intrusio..	2025-11-04 00:34:35	snort[15464]: [1:2008186:5] ET SCAN DirBuster Web App Scan in Progress [Classification: Web Application Attack] [Priority: 1] {TCP} 192.168.100.10:38253 -> 192.168.10.2:80
Intrusio..	2025-11-04 00:34:35	snort[15464]: [1:2008186:5] ET SCAN DirBuster Web App Scan in Progress [Classification: Web Application Attack] [Priority: 1] {TCP} 192.168.100.10:57811 -> 192.168.10.2:80
Intrusio..	2025-11-04 00:34:35	snort[15464]: [1:2008186:5] ET SCAN DirBuster Web App Scan in Progress [Classification: Web Application Attack] [Priority: 1] {TCP} 192.168.100.10:40827 -> 192.168.10.2:80
Intrusio..	2025-11-04 00:34:35	snort[15464]: [1:2008186:5] ET SCAN DirBuster Web App Scan in Progress [Classification: Web Application Attack] [Priority: 1] {TCP} 192.168.100.10:38253 -> 192.168.10.2:80

```
msf6 > use auxiliary/dos/http/slowloris
msf6 auxiliary(dos/http/slowloris) > set rhost 192.168.10.2
rhost => 192.168.10.2
msf6 auxiliary(dos/http/slowloris) > run
[*] Starting server...
[*] Attacking 192.168.10.2 with 150 sockets
[*] Creating sockets...
[*] Sending keep-alive headers... Socket count: 150
[*] Sending keep-alive headers... Socket count: 150
[*] Sending keep-alive headers... Socket count: 150
[*] Sending keep-alive headers... Socket count: 150
[*] Sending keep-alive headers... Socket count: 150
```



Slowloris DoS attack

- Finally, we ran Slowloris exploit in the metasploit console to see if it would be successful against our firewall.
- Test was extremely successful – the web server could not be accessed from other machines in the green zone, and the IPS could not recognize the attack.

Introduction pfsense

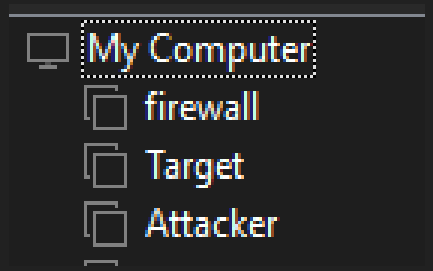
The project used pfSense, a FreeBSD-based firewall running on the pf (Packet Filter) engine.

pfSense allows you to build your own router with flexible security settings.





Virtual environment



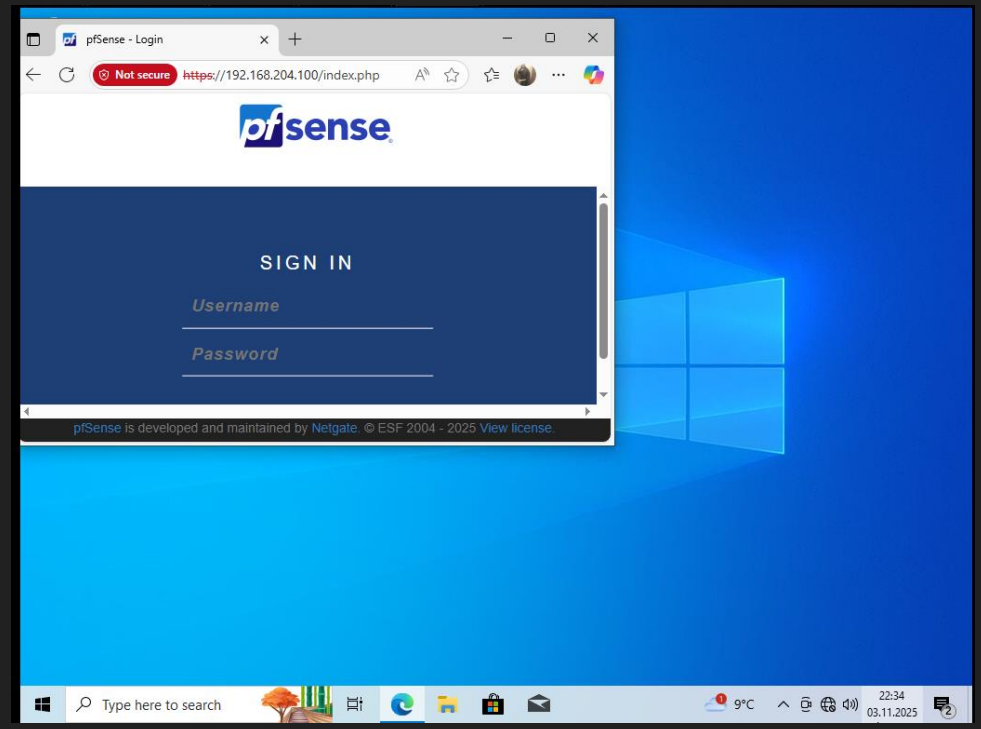
Three virtual machines were created:

Firewall — pfSense

Target (Victim) — Windows 10

Attacker — Kali Linux

The goal is to simulate a network with an attacker, a victim, and a defense device.



Network setup

Two network adapters were configured on the

network WAN — internet access

Firewall machine: Host-Only (LAN) — local area

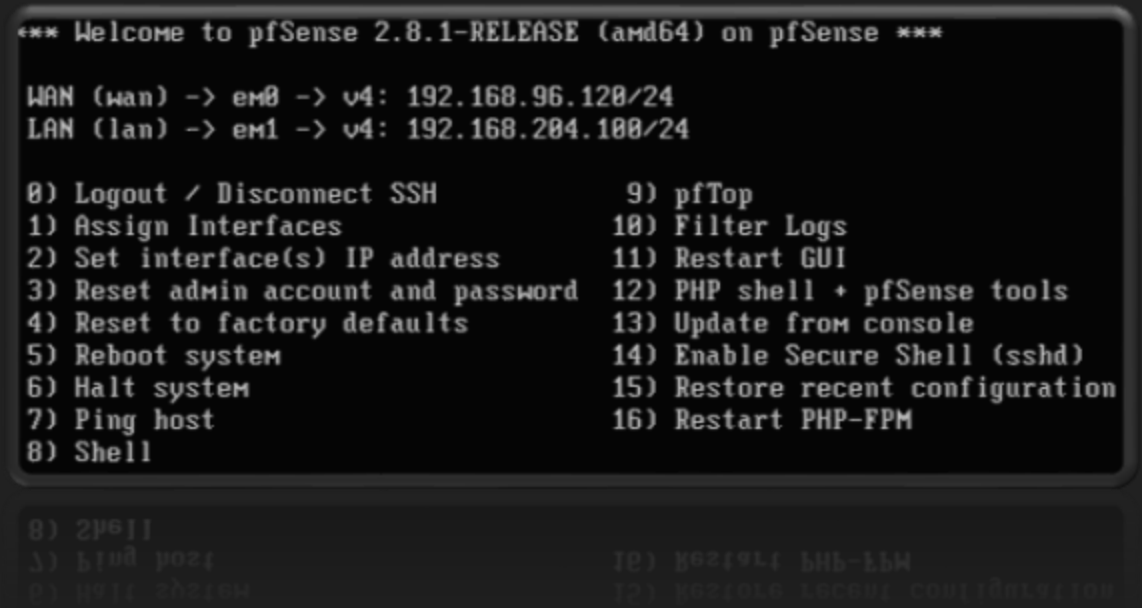
Addresses configured:

WAN (em0) - **192.168.96.120/24** DHCP range: **192.168.96.121–192.168.96.150**

LAN (em1) - **192.168.204.100/24** DHCP range:**192.168.204.100–192.168.204.150**

pfSense configuration

After installing the ISO image and pfSense itself, the user is presented with a menu consisting of sixteen configuration items.



Using option 2) Set interface IP address, the WAN and LAN interfaces were configured - they were assigned static IP addresses and DHCP ranges were specified.

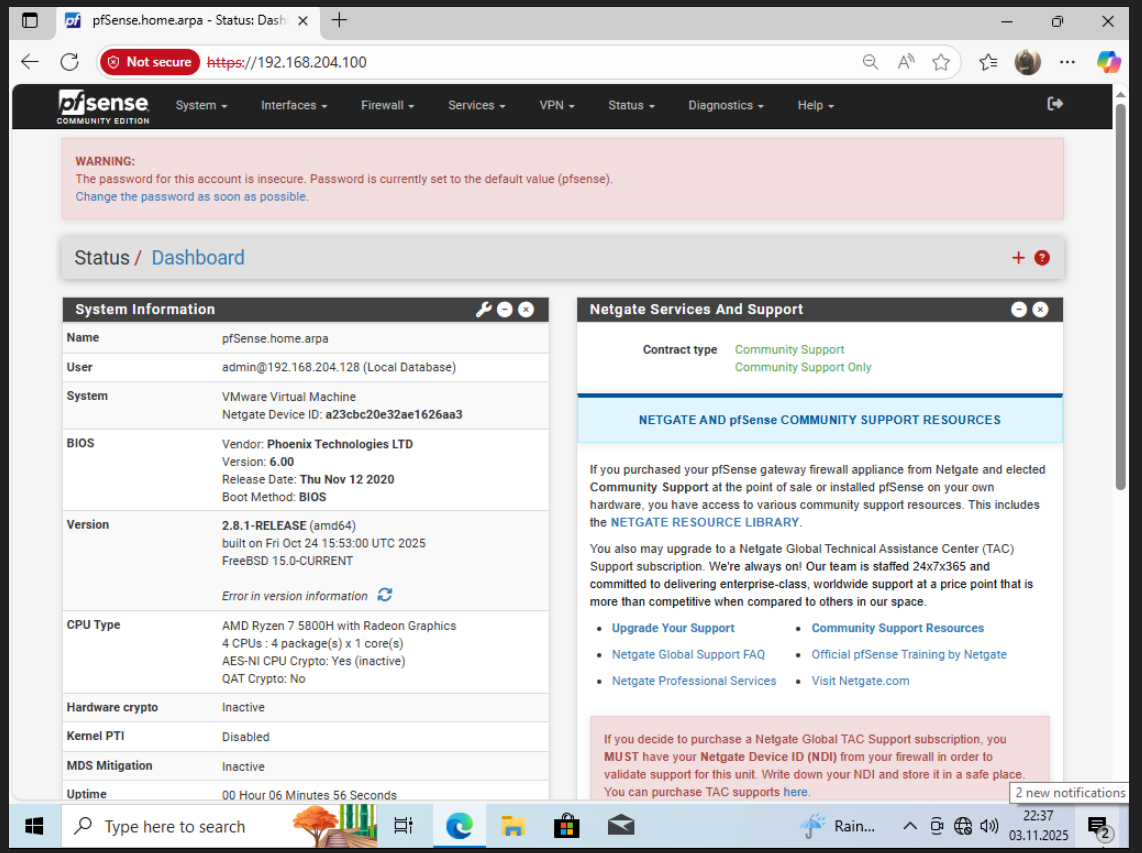
```
Enter an option: 2

Available interfaces:

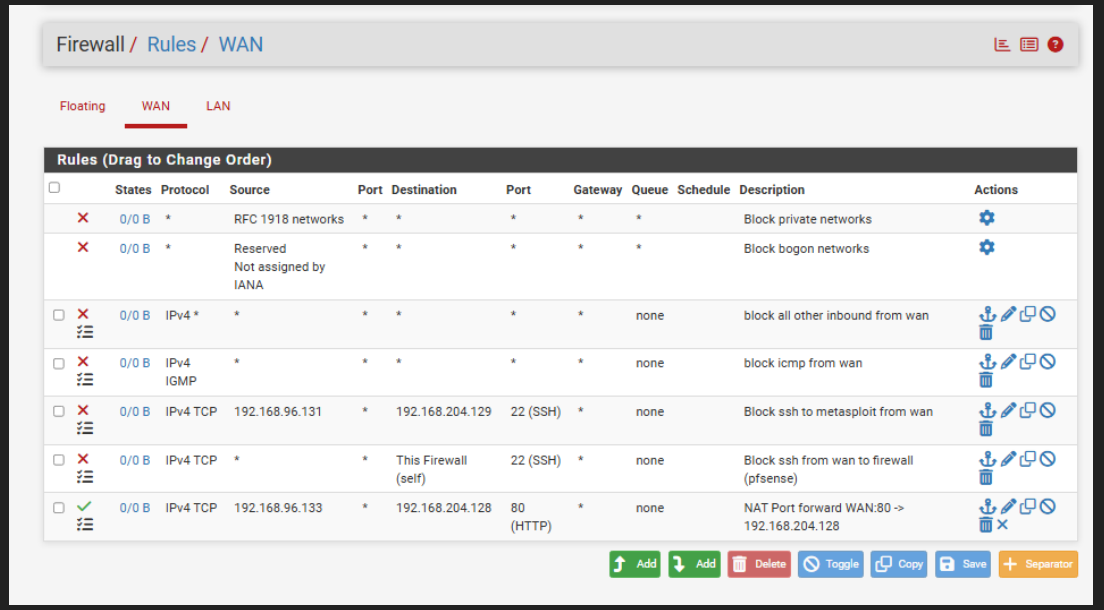
1 - WAN (em0 - static)
2 - LAN (em1 - static)

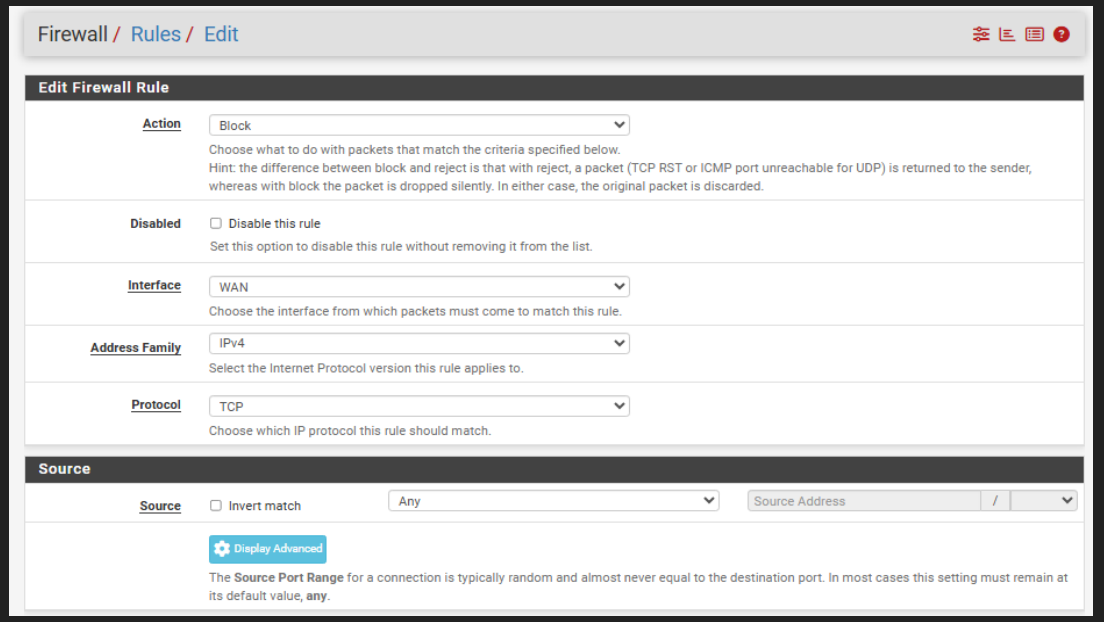
Enter the number of the interface you wish to configure:
```

After the basic configuration, further configuration was performed through a user-friendly web interface (GUI), which allowed for quick creation of security rules and network management.



Rules were created in the pfSense web interface to restrict traffic from the Attacker subnet. The primary goal was to protect the local area network (LAN) and the Target machine's resources from unauthorized access.





Testing SHH and ping

```
┌──(pavlo㉿attacker)-[~]
└─$ ssh -oHostKeyAlgorithms=+ssh-rsa \
-oPubkeyAcceptedKeyTypes=+ssh-rsa \
pasha@192.168.204.128
ssh: connect to host 192.168.204.128 port 22: Connection timed out
```

Ping attempts from the Attacker machine to the Target were blocked. This confirms that the firewall rules also apply to ICMP traffic, preventing network reconnaissance.

Connection blocked - port 22 is closed by the firewall for the attacker's subnet

```
┌──(pavlo㉿attacker)-[~]
└─$ ping 192.168.204.128
PING 192.168.204.128 (192.168.204.128) 56(84) bytes of data.
^C
── 192.168.204.128 ping statistics ──
7 packets transmitted, 0 received, 100% packet loss, time 6128ms
```

Nmap and logs

The host is accessible, but all ports are in the "filtered" state—traffic is blocked by the firewall. pfSense successfully hides internal services from external scans.

```
┌──(pavlo㉿attacker)-[~]
└─$ nmap -sS -p1-1000 -Pn 192.168.204.128
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-03 23:07 GMT
Stats: 0:01:24 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 41.50% done; ETC: 23:10 (0:01:58 remaining)
Nmap scan report for 192.168.204.128
Host is up.
All 1000 scanned ports on 192.168.204.128 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap done: 1 IP address (1 host up) scanned in 201.38 seconds
```

✕	Nov 3 23:09:49	WAN	Block private networks from WAN block 192.168/16 (12014)	192.168.96.133:39370	192.168.204.128:630	TCP:S
✕	Nov 3 23:09:49	WAN	Block private networks from WAN block 192.168/16 (12014)	192.168.96.133:39370	192.168.204.128:62	TCP:S
✕	Nov 3 23:09:49	WAN	Block private networks from WAN block 192.168/16 (12014)	192.168.96.133:39370	192.168.204.128:293	TCP:S
✕	Nov 3 23:09:49	WAN	Block private networks from WAN block 192.168/16 (12014)	192.168.96.133:39370	192.168.204.128:876	TCP:S
✕	Nov 3 23:09:50	WAN	Block private networks from WAN block 192.168/16 (12014)	192.168.96.133:39368	192.168.204.128:751	TCP:S
✕	Nov 3 23:09:50	WAN	Block private networks from WAN block 192.168/16 (12014)	192.168.96.133:39368	192.168.204.128:869	TCP:S
✕	Nov 3 23:09:50	WAN	Block private networks from WAN block 192.168/16 (12014)	192.168.96.133:39368	192.168.204.128:870	TCP:S
✕	Nov 3 23:09:50	WAN	Block private networks from WAN block 192.168/16 (12014)	192.168.96.133:39368	192.168.204.128:37	TCP:S
✕	Nov 3 23:09:50	WAN	Block private networks from WAN block 192.168/16 (12014)	192.168.96.133:39368	192.168.204.128:351	TCP:S
✕	Nov 3 23:09:50	WAN	Block private networks from WAN block 192.168/16 (12014)	192.168.96.133:39368	192.168.204.128:877	TCP:S
✕	Nov 3 23:09:50	WAN	Block private networks from WAN block 192.168/16 (12014)	192.168.96.133:39368	192.168.204.128:353	TCP:S
✕	Nov 3 23:09:50	WAN	Block private networks from WAN block 192.168/16 (12014)	192.168.96.133:39368	192.168.204.128:411	TCP:S
✕	Nov 3 23:09:50	WAN	Block private networks from WAN block 192.168/16 (12014)	192.168.96.133:39368	192.168.204.128:807	TCP:S
✕	Nov 3 23:09:50	WAN	Block private networks from WAN block 192.168/16 (12014)	192.168.96.133:39368	192.168.204.128:221	TCP:S
✕	Nov 3 23:09:51	WAN	Block private networks from WAN block 192.168/16 (12014)	192.168.96.133:39370	192.168.204.128:751	TCP:S
✕	Nov 3 23:09:51	WAN	Block private networks from WAN block 192.168/16 (12014)	192.168.96.133:39370	192.168.204.128:870	TCP:S
✕	Nov 3 23:09:51	WAN	Block private networks from WAN block 192.168/16 (12014)	192.168.96.133:39370	192.168.204.128:869	TCP:S
✕	Nov 3 23:09:51	WAN	Block private networks from WAN block 192.168/16 (12014)	192.168.96.133:39370	192.168.204.128:221	TCP:S
✕	Nov 3 23:09:51	WAN	Block private networks from WAN block 192.168/16 (12014)	192.168.96.133:39370	192.168.204.128:807	TCP:S
✕	Nov 3 23:09:51	WAN	Block private networks from WAN block 192.168/16 (12014)	192.168.96.133:39370	192.168.204.128:411	TCP:S
✕	Nov 3 23:09:51	WAN	Block private networks from WAN block 192.168/16 (12014)	192.168.96.133:39370	192.168.204.128:877	TCP:S
✕	Nov 3 23:09:51	WAN	Block private networks from WAN block 192.168/16 (12014)	192.168.96.133:39370	192.168.204.128:351	TCP:S
✕	Nov 3 23:09:51	WAN	Block private networks from WAN block 192.168/16 (12014)	192.168.96.133:39370	192.168.204.128:37	TCP:S
✕	Nov 3 23:09:51	WAN	Block private networks from WAN block 192.168/16 (12014)	192.168.96.133:39370	192.168.204.128:353	TCP:S

Conclusion

- Both **Endian** and **pfSense** use **zone-based security policies** and successfully enforce traffic filtering rules. Both provide **DHCP**, **proxy**, and **IPS** services, offering reliable network segmentation and protection.
- However, testing showed clear differences:
  - **Endian's IPS** detected scanning attempts but **failed to mitigate a basic DoS attack.**
  - **pfSense**, in contrast, maintained stable protection and properly filtered malicious traffic.
  - **Endian Community Edition** receives updates rarely (last in 2023), while **pfSense** is actively maintained (latest in 2025).




Thank you for your attention!